

VeloCart Platform - Technical & Product Documentation

1. Authentication & Session Management

1.1 Login Flow

Users authenticate with email and password via POST `/api/v1/auth/login`. On success, the server returns a JWT access token (15 minute expiry) and a refresh token (30 day expiry, httpOnly cookie). Failed attempts are rate-limited to 5 per 10 minutes per IP address.

1.2 Multi-Factor Authentication

MFA is optional per-account, enabled in Account Settings. Supported methods: TOTP authenticator apps and SMS one-time codes. When MFA is enabled, login requires a second POST `/api/v1/auth/mfa/verify` call with the one-time code before tokens are issued.

1.3 Session Timeout Behavior

Access tokens expire after 15 minutes of issuance regardless of activity. The frontend silently refreshes using the refresh token cookie every 12 minutes. If the refresh token itself has expired, the user is redirected to the login page with their previous location preserved as a `return_to` query parameter.

1.4 Password Reset

Password reset is requested via POST `/api/v1/auth/reset-request` with an email address. A reset link valid for 1 hour is emailed if the account exists (the endpoint always returns 200 to avoid leaking account existence). The reset link token is single-use and invalidated after the first successful password change.

1.5 Account Lockout Policy

After 5 consecutive failed login attempts, the account is locked for 15 minutes. Locked accounts can still request a password reset, which, if completed, immediately lifts the lockout regardless of the timer.

2. User Management API

2.1 Create User

Creates a new user account. Requires admin scope.

```
POST /api/v1/users
```

```
Content-Type: application/json
```

```
Authorization: Bearer <admin_token>
```

```
{
  "email": "jane.doe@example.com",
  "name": "Jane Doe",
  "role": "member",
  "send_invite": true
}
```

Response 201:

```
{
  "id": "usr_8f2a1c",
  "email": "jane.doe@example.com",
  "status": "invited",
  "created_at": "2026-06-01T10:22:00Z"
}
```

2.2 Update User Role

Roles form a hierarchy: viewer < member < admin < owner. Only owners can promote another user to owner. Admins can manage viewer/member/admin roles but cannot modify another admin's role without owner approval.

2.3 Deactivate vs Delete

Deactivating a user (PATCH /api/v1/users/{id} with status=inactive) preserves all historical data and audit logs, and the seat is freed from billing. Deleting a user (DELETE /api/v1/users/{id}) is irreversible after a 30-day soft-delete grace period, during which an owner can restore the account via support.

3. Payments & Billing

3.1 Supported Payment Methods

Credit/debit cards (via Stripe), ACH bank transfer (US only, 3-5 business day settlement), and invoiced billing for Enterprise plans with net-30 terms.

3.2 Subscription Tiers

Pricing and included seats per tier:

Tier	Monthly Price	Included Seats	Overage per Seat
-----	-----	-----	-----
Starter	\$29	3	\$12
Growth	\$99	10	\$9
Scale	\$349	30	\$7
Enterprise	Custom	Custom	Negotiated

3.3 Failed Payment Handling

On payment failure, the account enters a 7-day grace period with full feature access. Three retry attempts are made on days 1, 3, and 6. If all retries fail, the account is downgraded to a read-only state on day 8 until payment succeeds.

3.4 Refund Policy

Refunds are prorated for annual plans cancelled within 30 days of purchase or renewal. Monthly plans are not eligible for partial-period refunds; cancellation takes effect at the end of the current billing cycle.

4. Search & Indexing

4.1 Index Update Latency

Newly created or updated records appear in search results within 2-5 seconds under normal load. During bulk imports (over 10,000 records), indexing latency can extend to several minutes; a queue depth metric is exposed at `GET /api/v1/search/index-status`.

4.2 Query Syntax

Supports field-scoped queries (field:value), boolean operators (AND, OR, NOT), and fuzzy matching with a trailing tilde (term~1 allows edit distance 1). Wildcard prefix matching is supported (term*) but suffix wildcards are not.

4.3 Localized Note

Nota para equipos internacionales: la búsqueda distingue entre region-es, y los resultados pueden variar según la configuración de idioma de la cuenta. Se recomienda establecer explícitamente el parámetro locale en cada solicitud de búsqueda para resultados consistentes.

5. Notifications

5.1 Delivery Channels

Notifications can be delivered via in-app, email, and webhook. Webhook delivery includes automatic retry with exponential backoff (up to 5 attempts over 24 hours) and signs each payload with an HMAC-SHA256 signature in the X-Signature header.

5.2 Notification Preferences

Users can mute individual notification categories independently. Security-related notifications (new device login, password changed) cannot be muted and are always delivered via email regardless of in-app preference settings.

5.3 Digest Mode

When digest mode is enabled, non-urgent notifications are batched into a single email sent at the user's configured local time (default 9am), rather than sent individually as they occur.

6. Reporting & Analytics

6.1 Standard Reports

Pre-built reports include: Active Users (daily/weekly/monthly), Feature Adoption, Churn Risk Score, and Revenue by Tier. Reports refresh on a rolling 24-hour cycle; real-time data is available only via the Live Dashboard, which samples at 1-minute intervals.

6.2 Custom Report Builder

Available on Growth tier and above. Supports up to 8 dimensions and 4 metrics per report, with export to CSV or scheduled email delivery. Custom reports referencing deleted fields are automatically disabled with an in-app notification to the report owner.

6.3 Data Retention for Analytics

Raw event data is retained for 13 months. Aggregated daily rollups are retained indefinitely. Deleting a workspace purges raw event data within 30 days but aggregated historical rollups are retained in anonymized form for platform-wide benchmarking.